A PRACTICAL SECURITY GUIDE

YOUR SUPPLIERS ARE YOUR SECURITY RISK



The Small Business Guide to **Third-Party Cybersecurity**

VENDOR ASSESSMENT | RISK SCORING | CHECKLISTS

ZIRLANDIA MILKOVIC

A PRACTICAL SECURITY GUIDE

YOUR SUPPLIERS ARE YOUR SECURITY RISK

The Small Business Guide to Third-Party Cybersecurity

ZIRLANDIA MILKOVIC

Your Suppliers Are Your Security Risk
The Small Business Guide to Third-Party Cybersecurity

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 5 November 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional. Cover and diagrams created by the author with design tools.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Door You Did Not Lock 4
Who This Book Is For 5
How to Use This Book 6
The Ten-Minute Supplier Check 7

CHAPTERS

1. The Chain You Cannot See 9
2. Find Every Supplier 14
3. Tier Them: What Can Each Supplier Reach? 17
4. Assess: Questions That Matter, Evidence That Counts 21
5. Score: Turn Answers into a Number 25
6. Contracts and Clauses That Protect You 31
7. Access Is the Real Risk 34
8. Software Suppliers: Code, Updates and Open Source 38
9. What the Law and Your Customers Expect 42
10. Keep Watching After You Say Yes 46
11. When a Supplier Is Breached 49
12. Your 30-Day Supplier Security Plan 52

CLOSING

Conclusion: Trust, Then Verify 54

APPENDICES

Appendix A: Supplier Register 55
Appendix B: Inherent-Risk Scoring Sheet 56
Appendix C: Control Scorecard 57
Appendix D: Supplier Security Checklists by Tier 58
Appendix E: Contract Clause Checklist 60
Appendix F: Offboarding Checklist 61
Appendix G: Supplier Incident Log 62
Appendix H: Starter Answers for Customer Questionnaires 63

BACK MATTER

Glossary 64
A Note on GDPRGard.eu 65
About the Author 66
Notes and Sources 67

Educational Disclaimer

This book is practical, educational guidance for small businesses, freelancers and small software companies. It is not legal, cybersecurity or data-protection advice, and it does not create a professional relationship between the author and the reader.

Laws, contracts, standards and attack methods differ by country and sector, and they change quickly. Check the current position with a qualified adviser, your insurer or your regulator before relying on anything here for a decision that matters.

Following the steps in this book may reduce your risk. It cannot guarantee that a supplier will not be breached, or that you will meet every legal or contractual duty. The scoring model is a **decision aid**, not a certification: it turns your own judgement into a repeatable number, and it is only as good as the answers you feed it. Checklists and clauses are starting points to adapt, not finished legal documents.

Companies and products are named only to illustrate public, reported events. Naming a company is not an accusation of wrongdoing beyond what is reported, and not naming one is not an endorsement.

Every business, person and product used in a worked example (Hartley & Dunn, Ines Calder, Lattice Ledger and their suppliers) is **fictional** and is labelled as such. Where the book describes a real case or rule, it is sourced in the notes at the back.

Introduction: The Door You Did Not Lock

You have probably locked your own doors. You use strong passwords, you turn on two-step sign-in, you keep your laptop updated. Then you hand a key to your accountant's software, a copy of your customer list to your email tool, administrator access to the freelancer who built your website, and a line of code from a stranger to your product.

None of that is careless. A modern business cannot run without suppliers. But every supplier you rely on is a door into your business that **someone else** locks, and you cannot see whether they did.

The attackers have noticed. They no longer need to beat your defences when they can walk through a supplier's. One widely quoted measure, the Verizon *Data Breach Investigations Report* for 2025, found that third parties were involved in 30% of the breaches it analysed, double the share of the year before.[1] The share is not the whole story, but the direction is clear: the chain is where the attacks are going.

For a large company, the answer is a team, a procurement process and a software platform. For you, it is a spreadsheet, an afternoon and a plan. This book gives you that plan. It follows one idea in every chapter:

> **The rule.** A supplier is a part of your security. Find them, rank them by what they can reach, check them in proportion to that reach, and keep watching after you say yes.

You will learn how to build a list of every supplier you actually have, how to **tier** them by the damage they could do, how to **assess** them with questions that matter, how to turn the answers into a **risk score** you can defend, which contract clauses to ask for, how to control the access you give, what to do when a supplier is breached, and how to be a good supplier yourself when your own customers send you a questionnaire. A 30-day plan at the end puts it all to work.

You do not need to be a security expert. You need to stop trusting by default.

Who This Book Is For

This book is for you if you run, manage or advise a small organisation and any of the following is true:

- **You run a small business** (up to a few dozen people) that depends on cloud software, outside contractors, an IT provider or an accountant, and you could not list every supplier that touches your data.

- **You are a freelancer or consultant** who holds client files, logins or data, and who also uses subcontractors, tools and platforms of your own.
- **You run a small software company**, a SaaS product or an agency, and you rely on hosting, open-source code, payment and analytics services, and support tools, while your own customers now send you security questionnaires.
- **A client, insurer or regulator has started asking** which suppliers have access to what, and what you have done to check them.

The book assumes no technical background. Technical terms are explained when they first appear and collected in the glossary. It is **not** a guide for large enterprises with security teams and procurement departments. Many ideas apply, but you will need heavier controls than a spreadsheet and a one-page policy can supply.

How to Use This Book

You can read the book in an evening, or use it as a manual. Chapters 1 to 3 explain the problem and build your supplier list and tiers. Chapters 4 and 5 are the core: **assess** and **score**. Chapters 6 to 8 cover the three levers that reduce the risk you find: **contracts, access and software**. Chapter 9 explains what customers and regulators expect. Chapters 10 and 11 are about **watching** suppliers and **responding** when one fails. Chapter 12 is a 30-day plan.

Look for these markers:

- **The rule.** A principle worth remembering, set in a dark panel.
- **Fictional.** A worked example using invented people and businesses. Three recur: **Hartley & Dunn**, an eight-person accounting firm; **Ines Calder**, a freelance designer who works with client systems; and **Lattice Ledger**, a fourteen-person software company.
- Check boxes (☐). A step you can tick off. Where a line is blank, write on it.

The appendices contain ready-to-use tools: a supplier register, an inherent-risk scoring sheet, a control scorecard, tiered supplier security checklists, a contract clause checklist, an offboarding checklist, an

incident log and starter answers for customer questionnaires. Copy them into a spreadsheet or print them.



The supplier security loop. Seven steps, repeated

The Ten-Minute Supplier Check

Before you rely on a supplier, or when you review one you already use, ask these questions. If you cannot answer one, that is your next task.

- ☐ What exactly do they do for us, and who inside the business owns the relationship?
- ☐ What data of ours (and of our customers) can they see, store or change?
- ☐ What access do they have to our systems, accounts or code?
- ☐ How quickly would we be in trouble if they stopped working tomorrow?

- ☐ Do they use multi-factor sign-in, and do we force it on our accounts with them?
- ☐ Can they show us something independent: a certificate, an audit report or a test summary?
- ☐ Which suppliers do **they** rely on for our data (sub-processors)?
- ☐ Will they tell us about a breach, and how fast, **in writing**?
- ☐ What happens to our data when we leave, and can we get it out?
- ☐ When did we last look at this supplier, and when will we look again?

CHAPTER 1

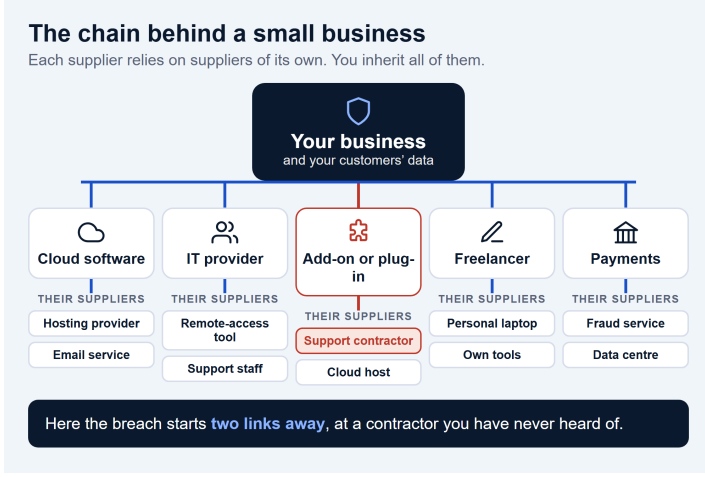
The Chain You Cannot See



> **Fictional.** Hartley & Dunn, Ines Calder, Lattice Ledger and every supplier named in the worked examples are invented for teaching. They are not real businesses or incidents.

Hartley & Dunn is an eight-person accounting firm. Its partner, Priya Hartley, is careful: every laptop is encrypted, every account has two-step sign-in, and the office Wi-Fi is locked down. Then one morning a client calls. Their payroll details have appeared in a phishing email that quotes the correct figures.

The investigation finds no flaw in Hartley & Dunn's own systems. The leak came from a **payroll add-on** that syncs data from the accounting software. The add-on's maker had been breached through a support contractor's stolen password. Nobody at the firm had ever read the add-on's terms, because it was installed "to try" by a junior colleague two years earlier. The firm's defences were strong. They were also beside the point.



The chain behind a small business. Every link is someone else's security

Why suppliers are where attackers go

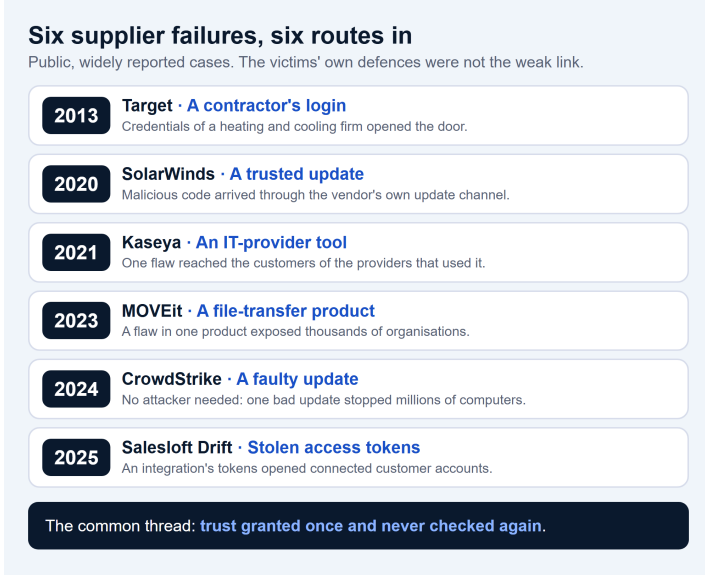
Attackers are economical. If one supplier serves five hundred customers, breaching the supplier is cheaper than breaching five hundred companies, and the small customers are protected by almost nothing the supplier has not provided. The Verizon 2025 report found third-party involvement in 30% of breaches, up from 15% a year earlier.[1] The share measures involvement, not blame, and it counts large organisations as well as small ones, but it is the best public indicator that supply chains are now a main route in.

Five shifts explain why this affects small businesses most:

1. **You run on other people's software.** Accounts, payroll, email, storage, design, booking, payment and support are all rented.
2. **Everything is connected.** Tools sign in to each other, read each other's data and call each other's interfaces, often with permissions nobody reviews.
3. **Suppliers hold your most valuable asset: other people's data.** Your customers did not choose your suppliers, but they will hold you responsible.
4. **Small suppliers are weakly defended.** The freelancer, the local IT shop and the niche app maker often have no security staff at all.
5. **You have little leverage.** A large provider will not negotiate with a five-person firm. You must choose well, configure carefully and plan for failure.

Six cases, one pattern

The incidents below are public and widely reported. They are listed to show a pattern, not to blame any victim.



Six supplier failures, six different routes

- **Target (2013).** Attackers entered through the credentials of a heating and cooling contractor, then moved into the retailer's payment systems.[2]
- **SolarWinds (2020).** A trusted update to widely used network-management software carried malicious code. The supplier later said around 18,000 customers had received the tainted update.[3]
- **Kaseya (2021).** A flaw in remote-management software used by IT providers let ransomware spread through those providers to their customers. Kaseya reported fewer than 60 direct customers and fewer than 1,500 downstream businesses affected.[4]
- **MOVEit (2023).** A vulnerability in a widely used file-transfer product was exploited at scale, exposing data held by thousands of organisations that used it or whose suppliers did.[5]
- **CrowdStrike (2024).** Not an attack: a faulty security-software update crashed an estimated 8.5 million Windows computers in one day. A supplier error can stop a business as surely as a criminal can.[6]
- **Salesloft Drift (2025).** Attackers stole access tokens tied to a chat-assistant integration and used them to read customer data held in connected Salesforce accounts, affecting hundreds of organisations. The scope is still disputed.[7]

The pattern: the victim's own defences were not the weak link. The weak link was **trust that had been granted once and never checked again**: a contractor's login, an update channel, an add-on, a token.

> **The rule.** You cannot outsource the risk. You can outsource the work, but the breach notice, the customer's anger and often the legal duty come back to you.

Where responsibility lands

In the UK and the EU, the law expects you to choose processors with sufficient guarantees and to bind them by contract (Chapter 9). In practice the regulator, your client and your insurer all start with *you*. The UK Information Commissioner's Office fined Capita £14 million in October 2025 after a 2023 cyber attack, a reminder that an organisation holding data on behalf of others can carry heavy liability.[8] Yours may be the name on the front door, but the incident will start in somebody else's building.



A hairline crack in any link and the chain is weaker than it looks

Meet the cast

Three fictional organisations run through the book. Between them they cover the kinds of reader it was written for.

- **Hartley & Dunn** (accountancy, eight people). It buys software and holds clients' financial data. Its risk is mostly in **cloud tools and add-ons**.
- **Ines Calder** (freelance designer and developer). She works inside her clients' accounts and subcontracts a developer. Her risk is mostly **access**.
- **Lattice Ledger** (a fourteen-person software company). It hosts a product, uses open-source code and third-party scripts, and answers customers' questionnaires. Its risk is the **software supply chain**, and also **being a supplier**.

What this chapter asks of you

- ☐ Name three suppliers you would be unable to work without for a day.
- ☐ Name three that could see customer or client data.
- ☐ Name the one person who would answer if a client asked, "who else sees my data?"

If the third answer is "nobody", you have found the first job.

CHAPTER 2

Find Every Supplier



You cannot assess what you have not found. The first step is a **supplier register**: one list, one owner, kept alive. It is dull, and it is the most valuable security document most small businesses do not have.

What counts as a supplier

A supplier is **anyone outside the business that provides a service, product, software or labour that touches your data, systems, customers or continuity**. That includes:

- Software and cloud services, paid or free: accounting, email, storage, CRM, design, project boards, e-signature, AI assistants.
- People: contractors, freelancers, agencies, virtual assistants, accountants, bookkeepers and outsourced support.
- Infrastructure: hosting, domain registrars, DNS, payment processors, internet and phone providers.
- Code: open-source libraries, plug-ins, scripts, widgets and APIs your product or website calls.
- Physical and professional: cleaners with office keys, shredding firms, the landlord's building-management system.

The test is not "do we pay them?" It is "**if they were compromised, could it reach us?**"

Five places to look

1. **Money.** Go through card statements, direct debits and expense claims for twelve months. Every recurring small payment is a supplier.
2. **Sign-ins.** Review your email provider's list of connected apps and the "sign in with Google / Microsoft" lists. Each one holds a token that can read your data.

3. **People.** A five-minute survey: *What do you use for work that is not on the official list?* Promise amnesty, or nobody will answer.
4. **Devices and browsers.** Look at the installed apps and browser extensions on work computers.
5. **Contracts and emails.** Search for "invoice", "renewal", "terms" and "agreement". Look for suppliers who bill by the project, not the month.

Freelancers should add one more: **client-provided access**. Every account a client created for you is a supplier relationship in reverse, and your subcontractors are suppliers to you.

Suppliers of suppliers

Your supplier has suppliers. Data-protection law calls them **sub-processors**; security people call them **fourth parties**. A payroll add-on may run on a large cloud, send email through another service and use a support platform that holds its tickets. Any of them may be where the incident starts.

You cannot audit that second ring, but you can **ask for the list** and read it. Many suppliers publish a sub-processor page. If a supplier cannot tell you who else touches your data, you have learned something important about them.

> **The rule.** One list, one owner, one rule: nothing touches business data unless it is on the register.

What to record

Keep it to the minimum that lets you decide. For each supplier record: its name and what it does, the **owner** inside your business, what data it sees, what access it has, the contract and renewal date, a link to its security and sub-processor pages, and its **tier** and **score** (you will add these in Chapters 3 to 5). Appendix A gives a ready-made register.

Fictional: what Hartley & Dunn found

Priya's firm believed it had eleven suppliers. The money check added six: two PDF tools, a time-tracking add-on, a backup service, an e-signature app and a mailing service. The sign-in check added four more apps with

access to the shared mailbox. A short staff survey produced three: a note-taking tool, an AI summariser and a free file transfer service. The final list had **twenty-four**. Fourteen were on a card statement; seven were free; five held client financial data.

Two of the free tools had no named owner, and the add-on behind the original leak was among the sign-ins nobody recognised.

What this chapter asks of you

- ☐ Create the register (Appendix A) and give it an owner.
- ☐ Run the five checks above and add every supplier you find.
- ☐ For every supplier, write down the name of the person who owns it.
- ☐ Open each supplier's sub-processor page, if there is one, and save the date you checked.

CHAPTER 3

Tier Them: What Can Each Supplier Reach?



A twenty-four-supplier register is too long to treat equally. The art of supplier security is **proportion**: spend your attention where a failure would hurt most. That is what tiering does.

The question is not "how good is this supplier?" (that comes later). It is "**how bad could it be if this supplier failed or were compromised?**" We call the answer **inherent risk**: the risk before you consider what the supplier does to protect you.



Five factors, each scored 1 to 5, decide the tier

Five factors, scored 1 to 5

Score each supplier on five factors. Use the highest score that fits.

1. Data (D). The most sensitive data the supplier can see or hold. 1 = none; 2 = business contact details; 3 = ordinary personal data or business confidential information; 4 = large volumes of personal data, or financial, HR or credentials; 5 = special-category data (such as health), payment card data, secrets and keys, or all your customers' data.

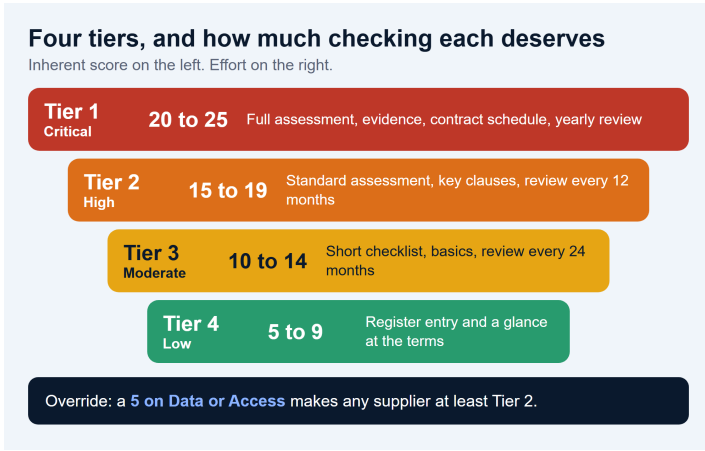
2. Access (A). How deeply the supplier can reach into your systems. 1 = none; 2 = reads a limited area through an account you control; 3 = reads and writes through an integration or token; 4 = administrator or network access; 5 = can run code or push updates in your systems, or controls your identity or keys (single sign-on, remote management, your build pipeline, scripts that run in your customers' browsers).

3. Criticality (C). How fast you are hurt if it stops. 1 = weeks; 2 = days; 3 = a working day; 4 = hours; 5 = revenue or service stops immediately.

4. Lock-in (L). How hard they are to replace. 1 = swap in a day; 2 = a week; 3 = a month; 4 = a quarter; 5 = more than six months or no practical alternative.

5. Reach (R). How far a failure travels to your **customers**. 1 = stays internal; 3 = affects some customers' service; 5 = your customers' data or systems are directly exposed.

Add the five scores for an **inherent score from 5 to 25**.



Four tiers, and how much checking each deserves

Four tiers

Inherent score	Tier	What it means	How much checking
20 to 25	**Tier 1: Critical**	Failure threatens the business or its customers	Full assessment, evidence, contract schedule, yearly review
15 to 19	**Tier 2: High**	Serious harm, but survivable	Standard assessment, key clauses, review every 12 months
10 to 14	**Tier 3: Moderate**	Limited harm	Short assessment, check the basics, review every 24 months
5 to 9	**Tier 4: Low**	Little reach	Register entry and a glance at the terms

Two override rules. A score of **5 on Data** or **5 on Access** makes the supplier at least Tier 2, whatever the total. And any supplier whose product runs inside your customers' browsers or devices is Tier 2 or higher.

Fictional: tiering Hartley & Dunn

Priya scores her cloud accounting platform, **LedgerLine**: Data 5 (client financial records), Access 3 (a connected bank feed), Criticality 5 (month-end stops without it), Lock-in 3, Reach 4. Total **20: Tier 1**.

The free form builder **FormFox**, used for client intake: Data 4, Access 2, Criticality 2, Lock-in 1, Reach 3. Total **12: Tier 3**. Not critical, but it holds identification documents. The note on the register: *small tool, real data.*

The scoring takes about two minutes a supplier. The twenty-four suppliers sort into two Tier 1, four Tier 2, eleven Tier 3 and seven Tier 4. Priya's attention now has a shape.

Common mistakes

- **Scoring the supplier's reputation, not its reach.** A famous brand with admin rights is higher inherent risk than an unknown app that sees nothing.
- **Forgetting people.** The freelance developer with production access may be a bigger inherent risk than the software vendor.
- **Scoring once.** Reach changes when you add an integration or a new data type. Re-score on change.

What this chapter asks of you

- ☐ Score every supplier on the register using Appendix B.
- ☐ Apply the two override rules.
- ☐ Sort the register by tier. Circle the Tier 1 and Tier 2 suppliers: they are your next chapter.

CHAPTER 4

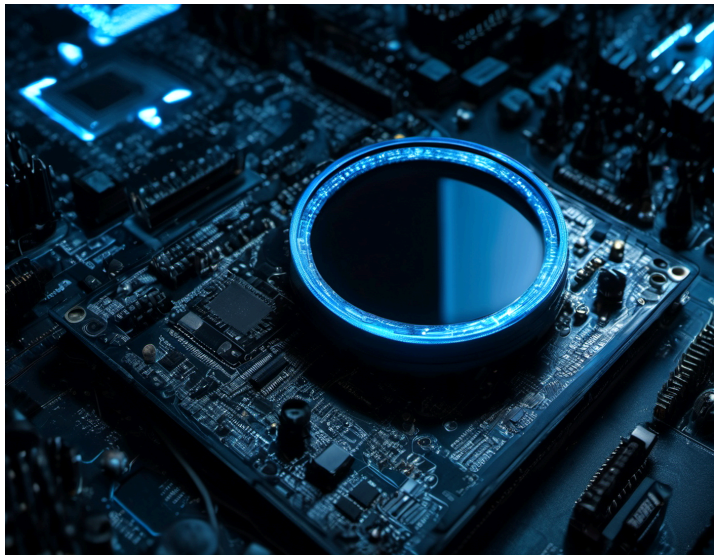
Assess: Questions That Matter, Evidence That Counts



Tiering told you where to look. Assessment tells you what is there. The aim is not a perfect audit. It is to learn whether the supplier has the **basic protections you would insist on in your own business**, and whether they can show you.

Match the effort to the tier

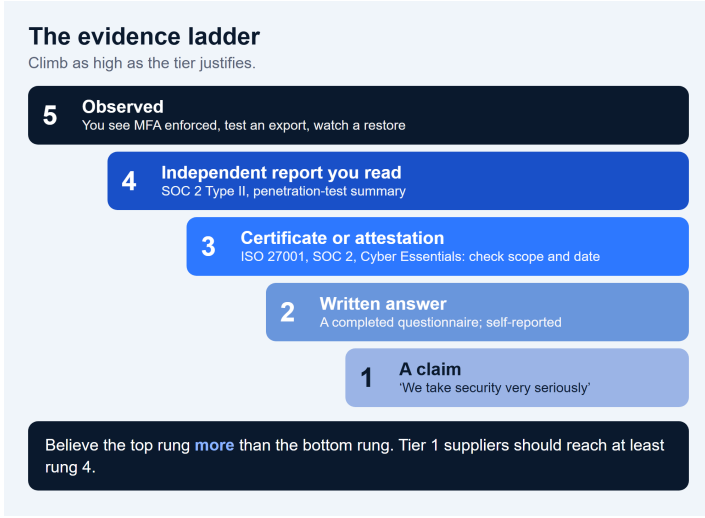
Tier	What you do	Time
1: Critical	Full control scorecard, review of an independent report, contract schedule, a call with the supplier's security contact	2 to 4 hours
2: High	Control scorecard, certificate or summary evidence, key clauses	1 to 2 hours
3: Moderate	Short checklist, public security page, terms and sub-processor list	20 to 30 minutes
4: Low	Read the terms, confirm sign-in options, note the verdict	5 minutes



Look closely before you trust. Evidence is what is left after the claims

The evidence ladder

Not all answers are equal. A supplier saying "we take security very seriously" is the weakest evidence there is. Think of evidence as a ladder and climb as far as the tier justifies.



The evidence ladder. The higher the step, the more you can believe

1. **A claim.** A marketing page or an email saying they are secure. Better than nothing, not much.
2. **A written answer.** A completed questionnaire. Useful, but self-reported.
3. **A certificate or attestation.** For example ISO/IEC 27001 certification, a SOC 2 report, or in the UK Cyber Essentials or Cyber Essentials Plus. [13][14] Check the **scope** (does it cover the service you use?), the **date** and the **issuer**.
4. **An independent report you read.** A SOC 2 Type II report, or a summary of a penetration test with the findings and fix dates.
5. **Something you can observe.** You see multi-factor sign-in enforced in your own admin console, you test an export, or you watch a restore.

How to read a certificate without being an auditor

- **Scope.** A certificate for "the head office" says nothing about the product. Look for the service name.
- **Date.** Certificates expire. SOC 2 reports cover a period; anything older than about a year needs a bridging statement.
- **Type.** A SOC 2 Type I describes controls at one date. **Type II** tests them over months. Prefer Type II for Tier 1.
- **Exceptions.** In a SOC 2 report, read the section on exceptions and management's response. A clean report is rare; unexplained exceptions matter more than their number.
- **Boundaries.** Check which sub-processors are carved out of the report. A cloud provider's own report does not cover the supplier's configuration.

A certificate shows a supplier has a **process**. It does not prove that your data is safe today.

Red flags

- No named security contact and no way to report a vulnerability. A published `security.txt` file or a security page is a good sign.[17]
- No multi-factor sign-in, or it is a paid extra.
- A refusal to say where data is stored or who the sub-processors are.

- Evidence that is out of date, out of scope or "available on request" and then never provided.
- Pressure to skip steps: "everyone uses us", "our other customers don't ask".
- No breach-notification commitment of any kind.

Ask small, specific questions

Long questionnaires get long, empty answers. For most small suppliers, a page of focused questions beats a hundred-line spreadsheet. Appendix D gives checklists by tier. A few questions do most of the work:

- Do all your staff use multi-factor sign-in, and can **we** enforce it for our users?
- How quickly do you apply critical security updates?
- Do you encrypt our data in transit and at rest, and who holds the keys?
- When did you last restore from backup and test that it worked?
- What is your commitment to tell us about a breach, and in what time?
- Which sub-processors handle our data, and do you flow your security terms down to them?
- What happens to our data when we leave?

Fictional: when the answers come back

Priya's firm assesses FormFox, the free form builder. Its security page is a marketing paragraph. It offers no multi-factor sign-in for accounts on the free plan, no sub-processor list and no breach commitment. The support reply to her three questions is: "Your data is safe with us." She records the answers as written and moves to scoring.

What this chapter asks of you

- ☐ Assess every Tier 1 and Tier 2 supplier using Appendix C and Appendix D.
- ☐ For each, record the **highest rung** of evidence you reached.
- ☐ Note the red flags you found. Do not argue yet. Score first.

CHAPTER 5

Score: Turn Answers into a Number



Assessment produces notes. Notes are hard to compare and easy to forget. A **score** gives you a single, explainable view of how much risk remains after the supplier's own protections. It lets you rank, set thresholds, show an insurer or customer how you decided, and see change over time.

Step one: the control score

Rate the supplier on ten control areas. Give each **0, 1 or 2**.



Ten control areas, each scored 0, 1 or 2

- **0 = none, or unknown.** Not in place, or you could not find out. *Unknown scores zero.*
- **1 = claimed.** The supplier says so in writing, but you have seen no proof.

- **2 = evidenced.** You have seen a document, report, certificate or setting that supports it.

The ten areas:

1. **Ownership.** A named security owner and a way to contact them.
2. **Access control.** Multi-factor sign-in, least privilege, and offboarding of staff.
3. **Encryption.** In transit and at rest, with sensible key handling.
4. **Patching.** Critical updates applied quickly; known vulnerabilities tracked.
5. **Logging and detection.** Activity is logged and someone looks at it.
6. **Backup and recovery.** Backups exist, are protected, and have been tested.
7. **Incident response.** A plan, and a written commitment to notify you.
8. **Fourth parties.** Sub-processors are known, listed and bound by the same terms.
9. **Independent assurance.** A current certificate, report or test covering the service.
10. **Data lifecycle.** Stated location, retention, deletion and export.

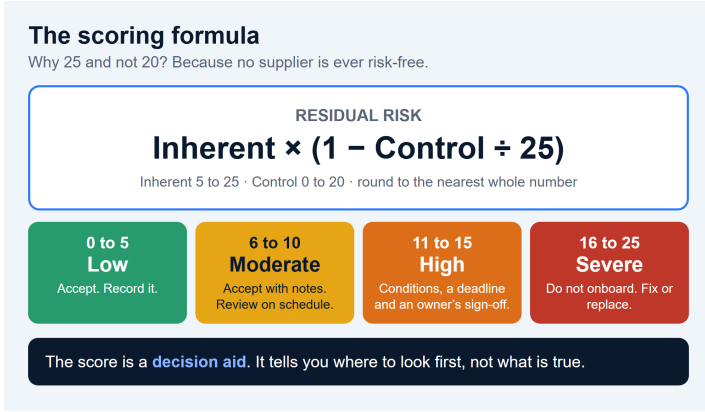
The total is the **control score from 0 to 20**.

Step two: residual risk

Combine inherent risk (Chapter 3) with the control score:

> **The rule.** Residual risk = Inherent score × (1 − Control score ÷ 25). Round to the nearest whole number.

The divisor is 25, not 20, on purpose: **no supplier ever scores zero risk.** Even perfect controls leave one-fifth of the inherent risk in place.



The scoring formula and what each band means

Residual score	Band	Decision
0 to 5	**Low**	Accept. Record it.
6 to 10	**Moderate**	Accept with notes. Review on schedule.
11 to 15	**High**	Accept only with conditions and a deadline. The owner signs off.
16 to 25	**Severe**	Do not onboard. For an existing supplier, fix or replace within an agreed time.

Here is the whole table at a glance. Each cell shows the residual score for a given inherent score (rows) and control score (columns).

Residual risk at a glance

Read down for the inherent score, across for the control score.

	0	4	8	12	16	20
Inherent 25	25	21	17	13	9	5
Inherent 20	20	17	14	10	7	4
Inherent 15	15	13	10	8	5	3
Inherent 10	10	8	7	5	4	2
Inherent 5	5	4	3	3	2	1

CONTROL SCORE →

Even a perfect control score leaves **one-fifth** of the inherent risk in place.

Residual risk by inherent score and control score

Worked examples

Five fictional suppliers, scored

Same method for a hosting giant and a freelancer.

LedgerLine Accounting platform	Inherent **20** Control **16**	**7** Moderate
FormFox Free form builder	Inherent **12** Control **3**	**11** High
Marco Freelance developer	Inherent **16** Control **4**	**13** High
NorthCloud Hosting provider	Inherent **24** Control **18**	**7** Moderate
ChatBridge Chat widget	Inherent **16** Control **6**	**12** High

The small, free tool and the freelancer landed in **High**. Size is not safety.

Five suppliers, scored

LedgerLine (Hartley & Dunn's accounting platform). Inherent 20 (Tier 1). The firm reviews a SOC 2 Type II report and sees multi-factor sign-in enforced. Control score: 16. Residual = 20 × (1 − 16/25) = 20 × 0.36 = 7.2, rounded to **7: Moderate**. Accept, note two exceptions in the report, review yearly.

FormFox (the free form builder). Inherent 12 (Tier 3). Almost nothing is evidenced; control score 3. Residual = 12 × (1 − 3/25) = 12 × 0.88 = 10.56, rounded to **11: High**. A "small" Tier 3 tool lands in High because it holds identity documents and offers no protection. Decision: move intake to a paid form tool within 60 days, and collect no ID documents there until then.

Marco (Ines Calder's freelance developer). Inherent: Data 3, Access 4, Criticality 2, Lock-in 2, Reach 5 = 16 (Tier 2). Marco uses a personal laptop, shared passwords and no multi-factor sign-in. Control score 4. Residual = 16 × (1 − 4/25) = 16 × 0.84 = 13.44, rounded to **13: High**. Ines does not drop Marco. She gives him his own accounts with multi-factor sign-in, moves him to a managed laptop profile and removes shared logins. Control rises to 10 and residual = 16 × 0.6 = 9.6, rounded to **10: Moderate**.

NorthCloud (Lattice Ledger's hosting provider). Inherent: 5 + 5 + 5 + 4 + 5 = 24 (Tier 1). A thorough SOC 2 Type II report and ISO 27001 certificate: control score 18. Residual = 24 × 0.28 = 6.72, rounded to **7: Moderate**.

ChatBridge (a chat widget Lattice Ledger embeds in its app). Inherent: Data 3, Access 5 (its script runs in customers' browsers), Criticality 2, Lock-in 1, Reach 5 = 16 (Tier 2). No assurance, a vague policy: control score 6. Residual = 16 × 0.76 = 12.16, rounded to **12: High**. Lattice Ledger isolates the widget on a separate page without access to customer data and sets a 90-day deadline to replace it.

> **The rule.** A high score is not a verdict on the supplier. It is a decision for **you**: fix it, shrink the access, accept it knowingly, or leave.

What the number cannot do

It is easy to fall in love with a number. Remember:

- **Garbage in, garbage out.** Scores reflect how honestly you filled them in. If you gave every unknown a 1, you deceived yourself.

- **Two suppliers with the same score can differ.** A "7" with a documented weakness in access control is not the same as a "7" with a weakness in backups. Keep the notes.
- **It is a snapshot.** Re-score on any trigger: a breach, an ownership change, new data, a new integration, or the annual review.
- **It is not a guarantee.** A low score reduces risk; it does not remove it.

What this chapter asks of you

- ☐ Complete the control scorecard (Appendix C) for each Tier 1 and Tier 2 supplier.
- ☐ Calculate residual risk. Write down the band and the decision.
- ☐ For every High or Severe result, write one named action, one owner and one date.

CHAPTER 6

Contracts and Clauses That Protect You



The scorecard tells you what to worry about. The contract tells you what the supplier **must do about it**. For small businesses, the contract is usually a standard set of online terms. You cannot rewrite them, but you can choose suppliers whose terms already contain the right protections, ask for an addendum where you are large enough to matter, and refuse to put Tier 1 data into a contract that says nothing.

Eight clauses worth looking for

1. Data processing agreement (DPA). If the supplier processes personal data for you, the GDPR requires a written contract setting out what it may do with the data (Article 28).[9] Most serious vendors offer a standard DPA. Sign it and file it.

2. Breach notification. Look for a commitment to notify you of a security incident **without undue delay and within a stated time**. For Tier 1 and Tier 2 suppliers, ask for 24 to 72 hours. Remember that you may have your own regulatory deadline of 72 hours from becoming aware of a personal-data breach.[9]

3. Security measures. A reference to specific measures, or to a named standard (for example ISO/IEC 27001 or SOC 2), rather than "appropriate security".

4. Sub-processors. A list, a right to be told of changes, and a right to object. The supplier remains responsible for their performance.

5. Audit and evidence rights. The right to receive current reports and certificates, answer a reasonable questionnaire, and for Tier 1, a limited audit or call.

6. Data location and transfers. Where the data is stored, and the legal mechanism if it leaves the UK or EEA.

7. Return and deletion. Export in a usable format on request and at exit, deletion within a stated period, and written confirmation.

8. Liability and insurance. Many standard terms cap liability at a few months of fees. That is rarely enough for a breach. Look for a higher cap for data-protection and confidentiality breaches, and for evidence of cyber insurance.

Beyond the checklist

- **Service levels.** Uptime, support response and, for critical suppliers, recovery time.
- **Change notice.** Notice of material changes to the service, the terms or the owner.
- **Termination assistance.** Help moving to a replacement.
- **Business continuity.** For Tier 1, a described continuity plan and an escrow or data-export arrangement if the supplier fails.

Choose, then negotiate, then walk

For most suppliers you will not negotiate. So the action is *selection*. When you compare two products, read the terms of each and prefer the one that gives you the clause, as a standard. Where the supplier is small, or your account is big enough, ask for an addendum with items 2, 4 and 7. Many will say yes.

When you cannot get the protections you need on a Tier 1 or Tier 2 supplier and the score stays High or Severe, the honest conclusion is that this supplier is wrong for this data. **Walk away, or keep the data out.**

Fictional: Lattice Ledger asks its provider

Lattice Ledger holds the customer data of forty small businesses and wants a 24-hour breach commitment from NorthCloud. The standard terms say "promptly". The company asks for a short addendum: notification within 48 hours, a published list of sub-processors with 30 days' notice of change, and export on request. NorthCloud agrees to all three. The cost: a ten-minute email.

What this chapter asks of you

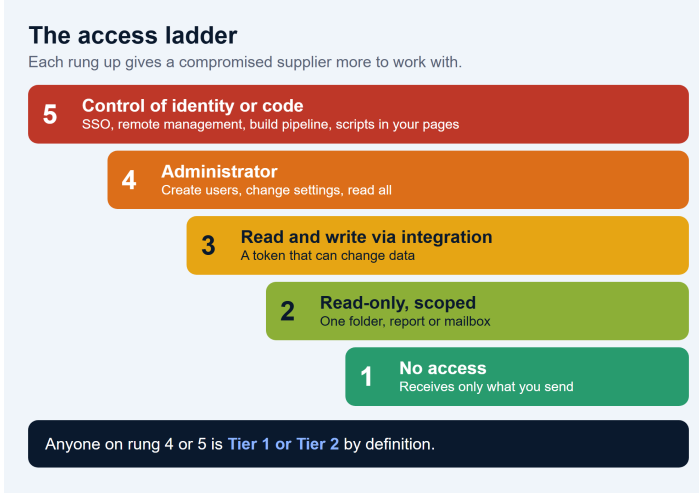
- ☐ Check Tier 1 and Tier 2 contracts against Appendix E.
- ☐ Sign and file every data processing agreement you are offered.
- ☐ Write down, per supplier, the breach-notification time the contract gives you. If it is "none", that is a finding.

CHAPTER 7

Access Is the Real Risk



When suppliers are breached, the damage that reaches you usually travels along **access**: a password, a token, an integration, an administrator role, a remote-management agent. You cannot control the supplier's defences. You can control how much of yours they hold.



Access is a ladder. Give each supplier the lowest rung that works

The access ladder

Every supplier sits on a rung, and each rung up gives an attacker who compromises them more to work with.

1. **No access.** The supplier receives only what you send.
2. **Read-only, scoped.** One folder, one report, one mailbox.
3. **Read and write through an integration.** A token that can change data.
4. **Administrator.** Can create users, change settings, read everything.
5. **Control of identity or code.** Single sign-on, remote management, your deployment pipeline, scripts in your pages.

The rule of thumb is **least privilege**: the lowest rung that lets the supplier do the job, for the shortest time.

> **The rule.** Every account, token and integration you give a supplier should be named, scoped, protected by multi-factor sign-in and reviewed on a date.



Every key you hand out should be on a list

Seven access controls that pay for themselves

1. **Separate accounts.** Never share a login. If a contractor leaves, you remove one account, not change a password everyone knows.
2. **Multi-factor sign-in, enforced.** Turn it on for every supplier account and every one of your accounts with them. Prefer an authenticator app or security key to text messages.
3. **Single sign-on where you can.** One door to guard, one place to switch off.
4. **Scoped tokens.** When an app asks for "full access to your mailbox", look for a narrower option or decline. Review connected apps quarterly.
5. **A role for the job.** Give the bookkeeper the finance role, not owner. Give the developer a staging account, not production.

6. **Expiry.** Set end dates on contractor access when you create it.
7. **Logs and alerts.** Turn on sign-in alerts, and review the audit log of your most important systems on a schedule.

OAuth and tokens: the access you forgot you gave

The Salesloft Drift incident showed how this works.[7] A user connects an app with a click. The app receives a **token**, a digital key that keeps working without a password and often without multi-factor sign-in. If the app's maker is breached, whoever holds the stolen tokens can read the data the token allows, from a different country, silently.

The defence is dull and effective:

- Review the **connected apps** page in your email, storage, CRM and accounting tools every quarter.
- Remove anything unrecognised or unused.
- For every remaining app, ask: what can it read, and what would I lose if a stranger could do that?
- Use admin settings to **require approval** for new connected apps, if available.

Contractors and freelancers

People are suppliers too, and often the most exposed. Practical rules:

- Create **named accounts** with the minimum role and an end date.
- Require multi-factor sign-in and a screen lock on the devices they use.
- Keep client data **out of their personal email and chat**.
- Include confidentiality and security terms in the engagement letter (Appendix E).
- Remove access on the **last day**, not "when we remember".

Freelancers face the reverse side: your clients are trusting you with access. Treat client credentials like cash. Use a password manager, never keep them in plain files, and delete access when the project ends.

Fictional: Ines Calder tightens up

Ines audits her own work and finds she holds logins to eleven client systems, three of them stored in a notes app with no multi-factor sign-in. Two former clients never removed her. She deletes the notes, moves all logins to a password manager with a hardware key, asks clients to give her named accounts with expiry dates, and sends a short note to the two old clients: *Please remove my access; the project ended in March.* Her own supplier, Marco, receives the same treatment.

What this chapter asks of you

- ☐ Open the connected-apps page of your email, storage and accounting tools. Remove what you do not recognise.
- ☐ Turn on multi-factor sign-in for every account a supplier or contractor can reach.
- ☐ Replace shared logins with named ones. Add end dates to contractor access.
- ☐ List every supplier on rung 4 or 5 of the ladder. They are Tier 1 or Tier 2 by definition.

CHAPTER 8

Software Suppliers: Code, Updates and Open Source



If you build or run software, even a modest website, your suppliers include **everything your code depends on**: hosting, open-source libraries, build tools, scripts and services you call. This chapter is mainly for small software companies and agencies, but anyone who runs a website with plug-ins is in the same position.



The software supply chain, from your code to your customers' browsers

Where the risk hides

- **Open-source dependencies.** A typical application depends on hundreds of libraries, which depend on others. A flaw in one, as with the Log4Shell vulnerability of December 2021, becomes your flaw.[16]

- **Update channels.** The SolarWinds incident showed that an update from a trusted supplier can carry malicious code.[3] The same channel is how you receive fixes, so the answer is control, not refusal.
- **Build and deployment.** The systems that compile, test and release your code can be a route to inject changes. Whoever holds the keys to the pipeline controls the product.
- **Third-party scripts.** A chat widget, analytics tag or payment form that loads in your customers' browsers runs with your reputation behind it.
- **Hosting and cloud accounts.** The administrator console of your cloud provider is a Tier 1 asset. Its sign-in deserves your strongest protection.
- **Plug-ins and themes.** On a content-management system, a forgotten plug-in is often the way in.



Behind every product is a stack someone else maintains

Seven habits for a small team

1. **Know what you depend on.** Keep a list of direct dependencies and their versions. A software bill of materials (SBOM) formalises the list, and some customers now ask for one.[16]
2. **Update on a schedule.** Apply security updates for libraries and plug-ins weekly; critical ones the same day.
3. **Pin and verify.** Lock dependency versions, and use the registry's checks and your tools' vulnerability alerts.

4. **Protect the pipeline.** Multi-factor sign-in for your code host and cloud console, separate deployment credentials, no secrets in code.
5. **Limit third-party scripts.** Load as few as possible, from named sources, and isolate them from pages that handle sensitive data.
6. **Back up and rehearse.** If your host or a critical service fails, how quickly can you rebuild?
7. **Watch for security notices** from your key suppliers and for the advisories in the ecosystems you use.

When you are the supplier

If your customers include other businesses, you are in someone's register. Expect their questionnaires, and answer them as you would want to be answered.

- **Keep a standard answer pack.** Appendix H gives starter answers for the twenty questions you will see most often. Update them twice a year.
- **Publish a short trust page.** Hosting location, sub-processors, security contact, uptime history, DPA download and your breach-notification promise. It saves hours of email.
- **Be honest about gaps.** "Not yet. Planned for Q2" is a better answer than an inflated claim that a customer later disproves.
- **Evidence beats adjectives.** A penetration-test summary, a policy extract, a screenshot of enforced multi-factor sign-in.
- **Consider a standard.** Cyber Essentials in the UK, or ISO/IEC 27001 or a SOC 2 report as you grow, can replace dozens of questionnaires.[13][14]

The EU **Cyber Resilience Act** adds duties for manufacturers of products with digital elements. Its reporting obligations for actively exploited vulnerabilities and severe incidents began to apply on 11 September 2026, with the main requirements following in December 2027.[12] If you sell software or connected products into the EU, check whether you are a manufacturer under the Act, and what your customers will therefore ask of you.

Fictional: Lattice Ledger's dependency scare

A widely used library in Lattice Ledger's product is reported to contain a serious flaw. Because the company keeps a list of dependencies, the engineer finds in ten minutes that the library is used in two places, ships a patch the same day, and sends customers a three-line note. A competitor with no list spends three days looking.

What this chapter asks of you

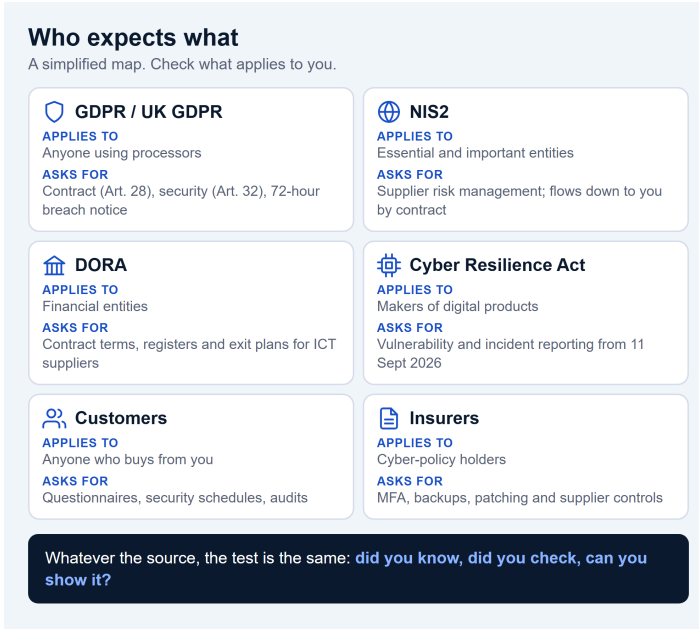
- ☐ Write down the hosting provider, code host, build service, payment service and every third-party script you use. Score each.
- ☐ Turn on multi-factor sign-in for the cloud console and code host. Enforce it.
- ☐ Choose a day each week for dependency updates.
- ☐ If you sell to businesses, create your answer pack and a trust page.

CHAPTER 9

What the Law and Your Customers Expect



You do not need to be a lawyer to see the pattern. Across Europe and the UK, data-protection law, network-security law and customer contracts all push in one direction: **know your suppliers, bind them, and be able to prove it**.



Who expects what of you, and of your suppliers

Data protection: the GDPR and UK GDPR

If a supplier processes personal data for you, it is your **processor** and you are the **controller**. The GDPR requires you to use processors that provide sufficient guarantees, to bind them with a written contract (Article 28), to keep processing secure (Article 32), and to notify the regulator of a

personal-data breach within 72 hours of becoming aware of it (Article 33). [9] Processors must tell you without undue delay, and may use sub-processors only with your authorisation. Maximum fines are the higher of €20 million or 4% of annual worldwide turnover for the most serious infringements (Article 83).

In practice that means: a signed DPA with every processor, the sub-processor list, a record of what you assessed, and a breach plan. The UK GDPR and the Data Protection Act 2018 mirror these duties, with equivalent penalties.

NIS2 and DORA: duties that flow downhill

Two EU laws matter even if you are not directly in scope.

- **NIS2** (Directive (EU) 2022/2555) obliges "essential" and "important" entities in many sectors to manage supply-chain security, including the security of their direct suppliers and service providers (Article 21).[10] Whether *you* are in scope depends on your sector and size and on national law. But if you supply a business that is, expect **contract terms, questionnaires and audits** flowing down to you.
- **DORA** (Regulation (EU) 2022/2554) has applied since 17 January 2025 to financial entities and their critical ICT service providers, with detailed rules on contracts, registers and exit plans for third-party providers.[11] If you sell to banks, insurers, investment firms or payment companies, you are likely to see these requirements in your contracts.

Customer questionnaires

Most small suppliers meet security regulation not through a regulator, but through a **customer questionnaire** or a contract schedule. The questions track the same topics as this book: access control, encryption, incident response, sub-processors and evidence. Companies that have done the work in Chapters 2 to 6 can answer quickly, and often win the deal.

Insurers

Cyber-insurance applications now ask whether you use multi-factor sign-in, back up and test, patch quickly and manage suppliers. A supplier register, a tiering method and a breach plan are strong answers. A false answer can void a claim, so answer from your records.

Standards worth knowing

You do not have to implement them, but they are a useful shared language.

- **Cyber Essentials / Cyber Essentials Plus** (UK, NCSC): a basic, affordable certification. Good for freelancers and small firms.[13]
- **ISO/IEC 27001**: an international management standard for information security. Common in business-to-business sales.[14]
- **SOC 2**: an American attestation report on controls, widely used by software suppliers.[14]
- **NIST Cybersecurity Framework 2.0** (February 2024) includes a dedicated supply-chain risk management category, and NIST SP 800-161 gives detailed guidance.[13][15]

What it adds up to

> **The rule.** Regulators and customers rarely ask for perfection. They ask: *did you know who your suppliers were, did you check them in proportion to the risk, and can you show it?* A register, a score and a dated decision answer all three.

Fictional: Hartley & Dunn's DPA sweep

Priya finds that five of her suppliers process client data, but she has signed DPAs for only two. She downloads the other three from the suppliers' sites, signs them, files them and notes them on the register. Total time: forty minutes. The next time a client asks for proof, the answer is on one page.

What this chapter asks of you

- ☐ List every supplier that processes personal data for you. Check that each has a signed DPA.
- ☐ Note the breach-notification time that the contract allows. Compare it with your own 72-hour duty.
- ☐ Check whether any of your customers is a regulated entity. If so, ask what they will require of you.

- [ ] Save your register, scores and decisions where an auditor, insurer or customer could be shown them.

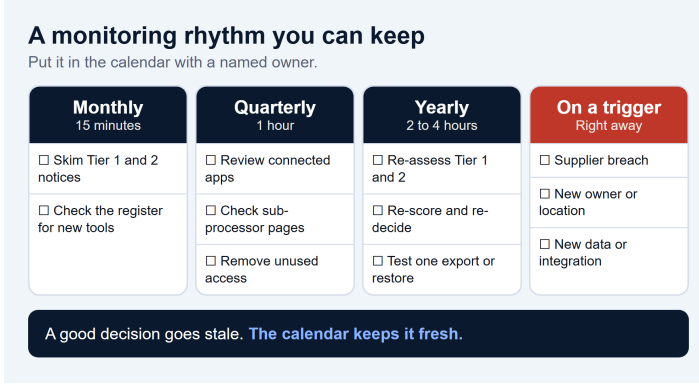
CHAPTER 10

Keep Watching After You Say Yes



The most common supplier-security failure is not a bad decision. It is a **good decision that went stale**. A supplier that scored well last year is sold, changes its hosting, adds a sub-processor or has a breach, and your register still says "Moderate".

Monitoring does not need tools or a budget. It needs a calendar, a few alerts and the habit of asking *what changed*?



A monitoring rhythm a small business can keep

A rhythm you can keep

Monthly (15 minutes). Skim the news and security notices from your Tier 1 and Tier 2 suppliers. Check that the register still matches reality: new tools, new people, new integrations.

Quarterly (1 hour). Review connected apps and administrator lists. Remove unused access. Check sub-processor pages for changes. Review any supplier incidents.

Yearly (2 to 4 hours). Re-assess every Tier 1 and Tier 2 supplier: new evidence, new score, new decision. Check the contract and renewal terms. Test one export or restore.

Every two years. Review Tier 3 suppliers. Prune Tier 4.

Triggers that force a re-score

Don't wait for the calendar when something material happens.

- The supplier **reports a breach** or is named in one.
- A change of **owner, hosting location or sub-processor**.
- **New data** (for example, adding customer ID documents) or a **new integration**.
- A change to **terms or pricing** that affects your rights.
- The supplier **loses a certificate** or lets it expire.
- A staff member with high access **leaves**.
- A **public vulnerability** in a product the supplier relies on.

Cheap ways to stay informed

- Subscribe to the supplier's **status page** and **security advisories**.
- Set a free news alert for each Tier 1 supplier's name plus "breach".
- Follow your national cyber-security centre's alerts.
- Add a calendar reminder for each certificate's expiry date.
- Ask your Tier 1 suppliers for a named contact and a notification route in the contract.

Offboarding done properly

Leaving a supplier is a security event. Use Appendix F:

1. Export what you need and test that it opens.
2. Revoke access: tokens, integrations, API keys, accounts.
3. Rotate any secret the supplier ever held.
4. Ask for deletion and get it **in writing**.
5. Cancel payment and update the register.
6. Tell anyone who relied on the supplier.

Fictional: the quarterly review that paid off

At Hartley & Dunn's quarterly review, Priya's associate notices that the backup service has added a new sub-processor in another country. The notice had gone to a mailbox nobody read. She checks the contract: it allows objection within 30 days. They have eleven days left. The firm asks for details, finds an adequate transfer mechanism and accepts. The same review finds a former intern's token still connected to the shared mailbox. It is removed.

What this chapter asks of you

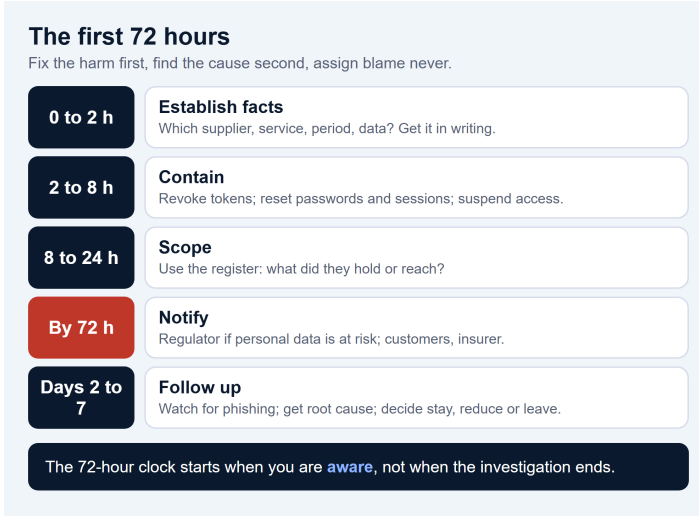
- ☐ Put the monthly, quarterly and yearly reviews in the calendar now, with named owners.
- ☐ Write the re-score triggers on the first page of the register.
- ☐ Route supplier security notices to a shared mailbox someone reads.
- ☐ Add an expiry-date reminder for every certificate you rely on.

CHAPTER 11

When a Supplier Is Breached



Sooner or later a supplier will tell you, or the news will tell you, that it has been breached. The first hours matter more than the next weeks. Preparation turns a panic into a procedure.



The first 72 hours, step by step

The first day

1. Establish facts. Which supplier, which service, which period, what data? Ask for a written statement. Save every message.

2. Contain. Revoke tokens and integrations. Reset passwords and sessions for every account the supplier could touch. Suspend access if the supplier is on the access ladder's top rungs. Do not wait for the full story.

3. Scope your exposure. Use the register: what did this supplier hold or reach? Which customers' data? Which accounts? Which systems depend on it?

4. Start the clock. If personal data is affected, you have 72 hours from becoming aware to notify the regulator, unless the breach is unlikely to result in a risk to people.[9] Awareness starts when you have reasonable certainty that a breach has occurred, which often means when the supplier tells you.

5. Decide who to inform. Your insurer (check the policy's notice period), your own customers if their data is affected, the regulator, and possibly the police. Appoint one person to lead and one to write.

Days two to seven

- Collect facts: what was accessed, for how long, and with what evidence.
- Watch for **follow-on attacks**. Stolen data is often used for phishing and fraud.
- Warn staff and customers about suspicious messages that quote real details.
- Ask the supplier hard questions: root cause, fixes, timeline and whether other suppliers were involved.
- Keep a log (Appendix G).

After the incident

- Re-score the supplier. Decide: **stay with conditions, reduce access, or leave.**
- Update your register, your contracts and your playbook.
- Share what you learned with your team. Blame teaches nobody anything.

A message you can adapt

> **Subject: Security incident at one of our service providers**
>
> We were informed on [date] that [supplier], which provides [service] to us, experienced a security incident. We have [taken the following steps]. The incident [may have/has not] involved your information, specifically [data types]. We recommend that you [actions, such as be alert to suspicious emails and change your password]. We will update you by [date]. Contact [name] at [email/phone] with any questions.

Say what you know, say what you do not yet know, and say when you will next update. Avoid guesses and avoid blame.

What a supplier's honesty looks like

How a supplier behaves in an incident is also evidence about its quality. Good signs: prompt, specific notice; clear instructions; frequent updates; an honest root-cause analysis. Warning signs: delays, vagueness, minimising language, and refusal to share facts.

Fictional: the first three hours at Lattice Ledger

At 07:40 a customer forwards Lattice Ledger a notice from its support-chat vendor. The vendor reports unauthorised access to its ticket system. The engineer on call opens the register: ChatBridge, Tier 2, Reach 5. By 08:15 she has disabled the widget, revoked its tokens and listed the data it could see: names, work emails and chat messages. At 09:30 the company sends customers a short notice. The report to the regulator is drafted by midday, and the clock for it started at 07:40.

What this chapter asks of you

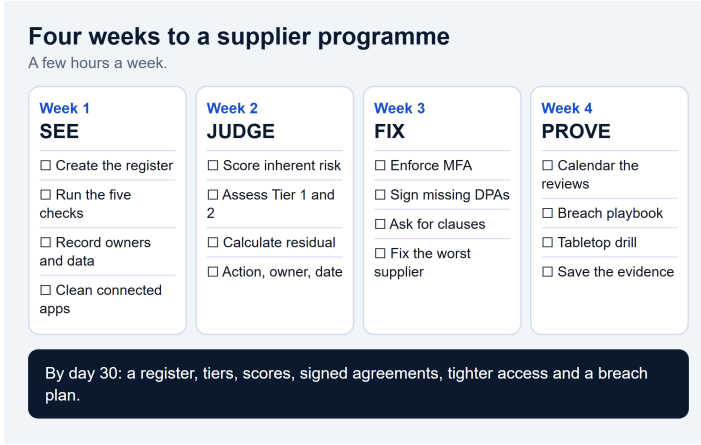
- ☐ Write a one-page supplier-breach playbook with names and phone numbers.
- ☐ Find your insurer's notice period and put it on the playbook.
- ☐ Store the customer notice template where you can reach it with your email down.
- ☐ Run a 30-minute tabletop exercise: "Supplier X says it has been breached. What do we do first?"

CHAPTER 12

Your 30-Day Supplier Security Plan



Four weeks, a few hours each week. At the end you will have a register, tiers, scores for your most important suppliers, a set of signed agreements, tighter access and a plan for when something goes wrong.



Four weeks to a supplier programme

Week 1: See

- ☐ Create the register (Appendix A) and name its owner.
- ☐ Find suppliers using the five checks of Chapter 2.
- ☐ Add the owner, data, access and renewal date for each.
- ☐ Open every connected-apps page and remove what you do not recognise.

Week 2: Judge

- ☐ Score the inherent risk of every supplier (Appendix B) and sort into tiers.

- ☐ Assess every Tier 1 and Tier 2 supplier with Appendices C and D.
- ☐ Calculate residual risk. Mark High and Severe results.
- ☐ Write one action, owner and date for each High or Severe result.

Week 3: Fix

- ☐ Enforce multi-factor sign-in on every Tier 1 and Tier 2 account.
- ☐ Sign missing data processing agreements.
- ☐ Ask Tier 1 suppliers for breach-notification and sub-processor commitments.
- ☐ Remove, replace or restrict the worst High or Severe supplier.

Week 4: Prove

- ☐ Put the monthly, quarterly and yearly reviews in the calendar.
- ☐ Write the breach playbook; run a 30-minute tabletop exercise.
- ☐ Test one export or restore from a Tier 1 supplier.
- ☐ Save the register, scores and decisions as evidence for customers, insurers and auditors.

If you only have one afternoon

Do these five things, in this order:

1. List your suppliers from card statements and connected apps.
2. Mark the five that hold the most data or the deepest access.
3. Turn on multi-factor sign-in for every account on those five.
4. Sign or download a DPA for each.
5. Write down who you would call if one of them was breached.

Conclusion: Trust, Then Verify



Suppliers are not the enemy. They are why a small business can look and work like a large one. The point is not to distrust them, but to stop trusting **blind**.

Everything in this book comes down to a handful of habits: list your suppliers, rank them by what they can reach, check them in proportion, turn the answers into a number, put the protections in writing, give the least access that works, keep watching and know what you will do on the worst morning.

None of that makes you immune. It makes you **prepared**, and prepared is what separates a bad day from a business-ending one. It also makes you the kind of supplier that other businesses want to work with.

Start with the afternoon plan. The next time a supplier has a bad day, you will be glad you did.

APPENDIX A

Supplier Register

Copy into a spreadsheet. One row per supplier. Review on the schedule in Chapter 10.

Supplier	What it does	Owner	Data it sees	Access (rung 1 to 5)	Contract / renewal	DPA signed?	Tier	Residual score	Next review

APPENDIX B

Inherent-Risk Scoring Sheet

Score each factor from 1 to 5. Add them up. Apply the override rules.

Factor	1	3	5	Score
Data	No data	Ordinary personal or confidential data	Special-category, payment, secrets, all customers	
Access	None	Read and write via an integration	Controls identity, code or updates	
Criticality	Weeks	A working day	Stops immediately	
Lock-in	A day to swap	A month	Over six months or none	
Reach	Internal only	Some customers' service	Customers' data exposed	
Total (5 to 25)				

Tier: 20 to 25 = Tier 1; 15 to 19 = Tier 2; 10 to 14 = Tier 3; 5 to 9 = Tier 4.

Overrides: Data = 5 or Access = 5 means at least Tier 2. Code that runs in customers' browsers means at least Tier 2.

Supplier: _____ **Scored by:** _____ **Date:** _____

APPENDIX C

Control Scorecard

Score each area 0 (none or unknown), 1 (claimed in writing) or 2 (evidenced). Total out of 20.

Area	What good looks like	0 / 1 / 2	Evidence seen
1. Ownership	Named security owner; reporting route		
2. Access control	Multi-factor sign-in; least privilege; leaver process		
3. Encryption	In transit and at rest; key handling		
4. Patching	Critical fixes applied fast; vulnerabilities tracked		
5. Logging and detection	Activity logged and reviewed		
6. Backup and recovery	Protected, tested backups		
7. Incident response	Plan; written notification commitment		
8. Fourth parties	Sub-processors listed; terms flowed down		
9. Independent assurance	Current certificate, report or test covering the service		
10. Data lifecycle	Location, retention, deletion, export stated		
Control score (0 to 20)			

Inherent score: _____ **Control score:** _____

Residual = Inherent × (1 − Control ÷ 25) = _____ **Band:** Low / Moderate / High / Severe

Decision: Accept / Accept with conditions / Fix by _____ / Leave

Owner: _____ **Date:** _____ **Next review:** _____

APPENDIX D

Supplier Security Checklists by Tier

Tier 4 (5 minutes)

- ☐ Terms read; business use permitted.
- ☐ Multi-factor sign-in available, and turned on.
- ☐ No data of other people shared with it.
- ☐ Owner named; entered on the register.

Tier 3 (20 to 30 minutes)

- ☐ All Tier 4 items.
- ☐ Privacy policy and sub-processor list read.
- ☐ Storage location is stated.
- ☐ A data processing agreement is available and signed (if personal data).
- ☐ Support or security contact found.
- ☐ Export and deletion process described.
- ☐ Breach-notification promise found (or flagged).

Tier 2 (1 to 2 hours)

- ☐ All Tier 3 items.
- ☐ Control scorecard completed (Appendix C).
- ☐ Certificate or report seen, scope and date checked.
- ☐ Multi-factor sign-in **enforced** for all our users.
- ☐ Breach notification time agreed in writing (24 to 72 hours).
- ☐ Sub-processors reviewed; change-notice right confirmed.
- ☐ Access scoped to the minimum; expiry date set.
- ☐ Export tested at least once.
- ☐ Renewal date and yearly review in the calendar.

Tier 1 (2 to 4 hours)

- ☐ All Tier 2 items.
- ☐ Independent report read (SOC 2 Type II, ISO 27001 scope, or a penetration-test summary).

- ☐ Exceptions and carve-outs in the report understood.
- ☐ Named security contact; call held.
- ☐ Contract schedule covers security measures, audit rights, liability and exit assistance.
- ☐ Business-continuity and recovery commitments in writing.
- ☐ Restore or failover tested, or evidence seen.
- ☐ Exit plan written (Appendix F).
- ☐ Residual score approved by a named senior person.

APPENDIX E

Contract Clause Checklist

Clause	What to look for	In place?	Note
Data processing agreement	Signed; covers purposes, security, sub-processors, deletion		
Breach notification	Stated time (24 to 72 hours) and content		
Security measures	Named standard or measures, not "appropriate"		
Sub-processors	List, change notice, right to object		
Audit and evidence	Reports, questionnaires, limited audit for Tier 1		
Location and transfers	Where stored; transfer mechanism		
Return and deletion	Export format; deletion period; written confirmation		
Liability and insurance	Cap suits the risk; cyber insurance		
Service levels	Uptime, support, recovery time		
Change notice	Notice of material changes and ownership change		
Termination assistance	Help with migration		
Subcontractors (for people)	Confidentiality; same security terms; named access		

APPENDIX F

Offboarding Checklist

Supplier: _____ **Owner:** _____ **Leaving date:** _____

- ☐ Replacement chosen and live (or no longer needed).
- ☐ Data exported; file opened and checked.
- ☐ All user accounts removed.
- ☐ Tokens, integrations and API keys revoked.
- ☐ Passwords or secrets the supplier knew rotated.
- ☐ Written request for deletion sent; confirmation received on _____.
- ☐ Backups: retention period and deletion date confirmed.
- ☐ Subscription and direct debit cancelled.
- ☐ Register updated; people who used the supplier told.
- ☐ Lessons noted for the next supplier review.

APPENDIX G

Supplier Incident Log

Date and time	Supplier	What we were told	Source	Data and systems affected	Actions taken	By whom	Notifications (regulator, customers, insurer)	Status

Decision after review: Stay with conditions / Reduce access / Leave. **Owner:** _____ **Date:** _____

APPENDIX H

Starter Answers for Customer Questionnaires

Adapt each answer to the truth. Never claim a control you cannot evidence.

Question	Starter answer	Evidence to attach
Do you use multi-factor sign-in?	Yes, enforced for all staff and for all administrator accounts.	Screenshot of the setting
Do you encrypt customer data?	Yes, in transit (TLS) and at rest.	Hosting provider documentation
How do you manage access?	Named accounts, least privilege, reviews every quarter, same-day removal for leavers.	Access review record
How quickly do you apply critical patches?	Within seven days; critical ones within 48 hours.	Patch log
Do you back up data, and do you test restores?	Daily, encrypted; restores tested twice a year.	Restore test record
Do you have an incident response plan?	Yes, reviewed yearly; we notify customers within 48 hours of confirmation.	Plan extract
Who are your sub-processors?	Listed on [trust page URL]; we give 30 days' notice of changes.	Sub-processor list
Where is data stored?	[Region / country].	Hosting details
Do you have independent assurance?	[Cyber Essentials / ISO 27001 / SOC 2 / penetration test, date].	Certificate or summary
How do you manage suppliers?	We keep a register, tier suppliers by risk and review them on a schedule.	Redacted register extract
What happens to data at the end of the contract?	Export on request; deletion within 30 days; written confirmation.	Policy extract
Do you train staff?	Yes, at onboarding and yearly, including phishing.	Training record

Glossary

Access token. A digital key that lets an application act on your behalf without your password, often without multi-factor sign-in.

Control score. In this book, a 0 to 20 rating of a supplier's security measures across ten areas.

Controller. The organisation that decides why and how personal data is processed.

DPA (data processing agreement). A contract binding a processor to handle personal data only on the controller's instructions, as Article 28 GDPR requires.

Fourth party. A supplier of your supplier. Under data-protection law, a sub-processor.

Inherent risk. The risk a supplier poses before considering its security measures.

Least privilege. Giving only the access needed for a task, for the time needed.

MFA (multi-factor authentication). Signing in with more than a password, for example a code from an app or a security key.

Processor. An organisation that processes personal data on behalf of a controller.

Residual risk. What remains after the supplier's controls are taken into account.

SBOM. A software bill of materials: a list of the components inside a piece of software.

SOC 2. A report from an independent auditor on a service provider's controls. Type I covers a date; Type II covers a period.

Sub-processor. A further supplier engaged by a processor to help handle personal data.

Supply-chain attack. An attack that reaches a target through a supplier, software update or service it trusts.

Third party. Any organisation outside your own that provides goods, services, software or labour to you.

Tier. A rank of suppliers (1 to 4) based on inherent risk, which decides how much checking each gets.

A Note on GDPRGard.eu

Managing suppliers sits beside a wider question: what does the GDPR expect of a small business? If this book has raised questions about data processing agreements, records of processing, privacy notices or breach response, GDPRGard.eu offers free tools, guides and articles written in plain language for small businesses. Look there for checklists you can use alongside the templates in this book.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes that security and privacy are not barriers to ambition but foundations of trust, and that business owners should not need a technical or legal degree to understand the risks they carry.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules and security practice into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other readers find it.

Notes and Sources

Research cut-off: 5 November 2026. Items marked (read) were consulted for this edition through news, trade and law-firm commentary; the others rest on the author's working knowledge of well-known public records and should be checked against the primary source before you rely on them.

1. Verizon, 2025 *Data Breach Investigations Report* (April 2025): third-party involvement in 30% of breaches, up from 15% (read, through Verizon's press material and coverage). It is a share of breaches analysed, not a count, and the sample is not representative of all businesses.
2. Target payment-card breach, November to December 2013: attackers used credentials of a refrigeration and heating contractor; about 40 million payment cards and about 70 million customer records reported. Widely covered; see also the US Senate Commerce Committee staff report (March 2014).
3. SolarWinds Orion compromise, disclosed December 2020; the company reported that around 18,000 customers received the affected update. See SolarWinds' regulatory filings and CISA Emergency Directive 21-01.
4. Kaseya VSA ransomware attack, 2 July 2021; Kaseya's later statements put direct customers affected at fewer than 60 and downstream businesses at fewer than 1,500.
5. Progress Software, MOVEit Transfer vulnerability exploited from late May 2023; the number of organisations and individuals affected differs between trackers and should be checked.
6. CrowdStrike content update, 19 July 2024; Microsoft estimated about 8.5 million Windows devices affected.
7. Salesloft Drift OAuth token theft, August 2025, attributed by Google's Threat Intelligence Group and Mandiant to UNC6395; Salesforce described a small number of customers, outside investigators estimated more than 700 organisations; scope and dates differ between sources (read, through security-press coverage).
8. UK Information Commissioner's Office, monetary penalty on Capita plc and Capita Pension Solutions Ltd, £14 million, announced 15 October 2025, following the 2023 cyber attack. Check ico.org.uk for the notice.
9. GDPR (Regulation (EU) 2016/679), Articles 24, 28, 32, 33, 34 and 83; EDPB Guidelines 07/2020 on the concepts of controller and processor; EDPB Guidelines 9/2022 on breach notification. UK equivalents: UK GDPR and Data Protection Act 2018.

10. NIS2 Directive (EU) 2022/2555, Article 21(2)(d) and 21(3) (supply-chain security) and Article 2 (scope). National transposition varies; check your country.
11. DORA, Regulation (EU) 2022/2554, applicable from 17 January 2025, Chapter V (management of ICT third-party risk).
12. Cyber Resilience Act, Regulation (EU) 2024/2847: reporting obligations for actively exploited vulnerabilities and severe incidents apply from 11 September 2026; the main obligations from 11 December 2027 (read, through Commission and law-firm commentary). Check the Regulation and ENISA guidance for the notification timeline.
13. UK National Cyber Security Centre: supply chain security guidance and the Cyber Essentials scheme; NIST Cybersecurity Framework 2.0 (February 2024), including the supply-chain risk management category.
14. ISO/IEC 27001:2022 and ISO/IEC 27036; AICPA SOC 2 and the Trust Services Criteria; Cloud Security Alliance STAR and CAIQ.
15. NIST SP 800-161 Rev. 1, *Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations*.
16. Log4Shell (CVE-2021-44228), December 2021; CISA guidance on software bills of materials; SPDX and CycloneDX formats.
17. RFC 9116, A *File Format to Aid in Security Vulnerability Disclosure* (security.txt).